

Executive Security Readout: Project KAVACH

Prepared for the Meridian FinServe Board of Directors

We recently commissioned an independent, unified security assessment to investigate anomalous network activity and reported weaknesses in our customer portal. The engagement treated our network and web applications as a single environment to mirror how real attackers operate. The results confirm that urgent structural improvements are required to protect our customer data and financial systems.

THREE KEY FINDINGS

- 1. Unrestricted Internal Network Access:** We identified that an infection on a single employee laptop can spread directly to our core infrastructure. Due to a "flat" internal network design, an attacker who compromises an employee can easily gain administrative control over the master servers that govern our entire company.
- 2. Critical Portal Vulnerabilities:** The customer-facing web portal suffers from foundational design flaws. An attacker can manipulate data inputs to bypass the login screen completely (SQL Injection) and view or alter other customers' account details by simply changing numbers in their web browser (Insecure Direct Object Reference).
- 3. Lack of Outbound Controls:** Our core servers currently possess unrestricted access to the public internet. During the assessment, simulated malware was able to establish a permanent, undetected communication channel and transmit collected data to external servers without being blocked by our firewalls.

THREE STRATEGIC RECOMMENDATIONS

- 1. Isolate Core Systems (Microsegmentation):** We must separate our regular employee networks from our critical financial servers. Administrative access to core servers should only be permitted through heavily monitored "jump" systems, preventing an infected laptop from touching our core databases.
- 2. Mandate Secure Engineering Standards:** We must pause new feature development on the customer portal to address the current vulnerabilities. The engineering team must implement modern, secure coding frameworks that automatically prevent data manipulation and enforce strict identity checks on every request.
- 3. Enforce Outbound Filtering:** We must implement a "default-deny" rule on our firewalls for all outbound traffic originating from our core servers. Servers should only be permitted to communicate with known, approved external services.

THE ASK

We are requesting the Board's approval for a **\$450,000 security remediation budget and a 60-day feature freeze** for the portal engineering team. This investment will fund the necessary network segmentation hardware, provide secure coding training for our developers, and afford the team the time required to eliminate these critical risks before a real breach occurs.